

Narrativa explicativa: de los objetivos nacionales a los logs de los agentes

1. De la estrategia país a la consola del SOC

Las estrategias nacionales de ciberseguridad hablan en términos de resiliencia, continuidad de negocio y protección de derechos fundamentales. Los agentes de IA, en cambio, hablan en tokens, herramientas y cadenas de razonamiento. El papel de este marco GQM + PRAGMATIC es traducir entre ambos idiomas.

GQM garantiza que cada métrica de Agentic IA nace de un objetivo explícito y una pregunta con sentido; PRAGMATIC comprueba si esa métrica merece vivir en los cuadros de mando o debería quedarse en el laboratorio.

2. Cómo se encadenan objetivos, preguntas y métricas

El recorrido típico es:

1. Objetivo nacional: reducir el impacto económico de los ciberataques y proteger los datos personales.
2. Objetivo organizativo: disminuir incidentes graves relacionados con agentes de IA y mejorar el tiempo de contención.
3. Objetivo GQM: controlar y reducir las acciones inseguras (UAR) y el tiempo de contención (TTC) de incidentes impulsados por Agentic IA.
4. Preguntas:
5. ¿Con qué frecuencia los agentes rompen las reglas?
6. ¿Cuánto tardamos en detectar y contener esas fechorías digitales?
7. Métricas: UAR y TTC, definidas con precisión, fuentes de datos y frecuencia.

Así, cuando la métrica sube o baja, se puede trazar una línea directa hacia el objetivo nacional que se está acercando... o alejando.

3. Por qué PRAGMATIC evita métricas “bonitas pero inútiles”

En muchos programas de seguridad abundan las métricas que son visualmente atractivas pero poco útiles: cuentan cosas fáciles de medir, no cosas importantes. PRAGMATIC obliga a hacer un examen de conciencia:

- ¿Esta métrica predice algo que importe?
- ¿Está ligada a decisiones reales que alguien pueda tomar mañana?
- ¿Es lo bastante precisa para justificar cambios de presupuesto, controles o políticas?

Si la respuesta es “no” en demasiados criterios, la métrica se mueve a la sección de curiosidades, no al reporte ejecutivo.

4. Ejemplos de lectura estratégica

- Un UAR alto con PED elevado sugiere no solo que los agentes se salen del guion, sino que además tienen demasiadas vías para escalar privilegios: una combinación inflamable para cualquier regulador o aseguradora.
- Un TTC que mejora tras introducir automatización Agentic en el SOC indica que no solo se ha ganado velocidad, sino que se han acortado las ventanas de explotación para los atacantes.
- Una política muy avanzada en papel pero sin métricas de PAR o OORAR es como un código de circulación sin radares: impecable en teoría, optimista en la práctica.

5. Orientación para decisores

Para la alta dirección y reguladores, el mensaje es doble:

- No basta con exigir “IA segura”: hay que definir objetivos claros y preguntas incómodas que la organización deba poder responder con evidencia.
- No basta con medirlo todo: hay que seleccionar un núcleo de métricas que puntúen alto en PRAGMATIC, para que cada número sea un argumento, no ruido.

6. Cierre

Si al final de este ejercicio la organización puede tomar decisiones presupuestarias, de arquitectura o de gobernanza apoyándose en UAR, PAR, PED, TTC y compañía, entonces las métricas han dejado de ser decorado y se han convertido en instrumentos. Y en ciberseguridad, como en música, los instrumentos bien afinados marcan la diferencia.